CONECTARIESGO / DOCUMENTACIÓN OFICIAL

Privacidad y seguridad

Marco operativo mínimo, diagnóstico técnico y controles prioritarios

CR-SEG-04 / VERSIÓN 1.0

Innovación social · Resiliencia territorial · Tecnología responsable

DOCUMENTO DE REFERENCIA

Privacidad y seguridad

Marco operativo mínimo, diagnóstico técnico y controles prioritarios

ALCANCE. Guía preparada a partir de ConectaRiesgo_Repositorio_GitHub_Depurado.zip, revisión del 19 de octubre de 2026. Distingue funciones identificadas en código, procedimientos recomendados y tareas aún pendientes.

Control documental

Campo	Información
Código	CR-SEG-04
Edición	1.0 · 19 de octubre de 2026
Iniciativa	Fundación Misión E TECH · Colaboración tecnológica: co/amplIA
Base técnica	PHP 8.2 · MySQL/MariaDB · Apache/cPanel · ZIP depurado
Estado	Material de referencia para pilotos y despliegues controlados; no certifica preparación para emergencias reales

1. Objeto y alcance

Esta guía identifica datos tratados y controles observables en el ZIP depurado, así como medidas recomendadas antes de una implementación con datos reales. No es un aviso de privacidad legalmente aprobado ni una auditoría de seguridad.

RECOMENDACIÓN DE USO. Mantener una instancia separada de demostración, con datos ficticios. No invitar a ciudadanos a remitir solicitudes reales hasta cerrar los riesgos críticos, formalizar responsabilidades y verificar la normativa ecuatoriana aplicable.

2. Inventario de información

Categoría	Campos o tratamiento	Sensibilidad
Reportes	Zona, coordenadas GPS, gravedad, indicadores, descripción y fotografía opcional.	Ubicación potencialmente individualizante y contenido aportado por usuario.
Solicitudes	Zona, GPS, necesidades, edades agregadas, discapacidad, evacuación, contacto y teléfono.	Muy sensible por contexto de vulnerabilidad, aunque no se registra historia clínica.
Cuentas	Nombre, correo, hash de contraseña, rol, organización y actividad de acceso.	Datos de identificación y autorización.
Registro técnico	Logs PHP, sesión con cookie, códigos de seguimiento, metadatos y fechas.	Puede revelar hábitos, errores y datos incidentales.
Visualización pública	Mapa, estados, referencias de sectores y fotos accesibles con código.	Requiere limitar precisión y accesibilidad.

3. Controles presentes en la base de código

- Conexión PDO con sentencias preparadas y emulación desactivada (bootstrap.php e index.php).
- Token CSRF en formularios POST y comprobación en handlers correspondientes.
- Sesiones configuradas con cookies HttpOnly y SameSite=Lax; Secure depende del HTTPS detectado.
- Filtrado y validación de coordenadas GPS en servidor; ubicación reciente confirmada en navegador mediante location.js.
- Archivo fotográfico limitado a JPEG/PNG/WebP, 5 MB, 12 megapíxeles, reencodificación JPEG y nombre aleatorio.
- Reglas .htaccess para restringir directorios internos y archivos sensibles bajo un Apache que respete dichas reglas.
- Consultas del panel protegidas por autenticación de sesión (require_auth).

4. Brechas técnicas prioritarias

Riesgo	Evidencia y tratamiento sugerido	Prioridad
Coordenadas públicas	/mapa publica coordenadas precisas de solicitudes y afectaciones; generalizar o restringir según tipo y riesgo.	Crítica
Autorización	Las rutas del panel solo exigen sesión; añadir permisos por rol y alcance territorial/organizacional.	Crítica
Foto con código	/foto puede accederse por código de reporte sin autenticación adicional; revisar confidencialidad y expurgación.	Crítica
Falsa sensación de demo	DEMO_MODE agrega un rótulo visual; no evita escritura de registros. Aislar BD o deshabilitar POST en demo pública.	Alta
Abuso de formularios	No se observa limitación por IP/cuenta, CAPTCHA ni protección antispam; definir controles sin excluir poblaciones.	Alta
Sesiones y login	No se observa regeneración de ID al iniciar sesión, MFA, limitación de intentos ni recuperación segura.	Alta
Validez de entradas	Varias opciones POST dependen del formulario; reforzar validación de enumerados, longitudes y códigos de zona.	Alta
Retención y derechos	No se identifica función de anonimización, eliminación bajo política o gestión de solicitudes de derechos.	Alta

5. Política mínima de datos para cada instancia

01. **Finalidad:** especificar por escrito para qué se recoge cada campo y qué institución decide sobre el tratamiento.
02. **Minimización:** recopilar solo lo estrictamente necesario; no solicitar datos de terceros ni imágenes de rostros o documentos.
03. **Base legal y transparencia:** preparar aviso ciudadano revisado por responsable jurídico y responsable de privacidad; distinguir reporte, mapa y contacto.
04. **Acceso:** cuentas individuales y permisos diferenciados para verificar, atender, auditar y administrar.
05. **Conservación:** establecer por escrito plazos por categoría y procedimiento seguro de eliminación o anonimización; el ZIP no define dichos plazos.
06. **Derechos:** habilitar canal verificable de consulta, rectificación, eliminación y atención de solicitudes conforme a la legislación aplicable.
07. **Terceros:** documentar hosting, mapas, soporte y posibles transferencias o procesadores externos.
08. **Incidentes:** tener un protocolo de clasificación, contención, notificación legal cuando corresponda y recuperación.

> **NOTA JURÍDICA.** Se requiere revisión particular de la Ley Orgánica de Protección de Datos Personales de Ecuador, sus normas de aplicación y los deberes institucionales. Este documento no determina por sí solo bases de legitimación, plazos legales ni obligaciones de notificación.

6. Endurecimiento del servidor

- ☐ No publicar .env, volcados SQL, fotografías reales ni archivos de logs en repositorios.
- ☐ Rotar credenciales expuestas previamente y usar claves únicas con privilegios mínimos.
- ☐ Proteger app/, database/, storage/ y .env por configuración Apache y, preferentemente, fuera de la raíz pública.
- ☐ Forzar HTTPS y comprobar las cabeceras reales en el hosting.
- ☐ Restringir acceso de escritura al filesystem y habilitar respaldos cifrados con restauración probada.
- ☐ Configurar actualizaciones, supervisión de errores y alertas de disponibilidad.
- ☐ Deshabilitar índices de directorios y exponer solo assets públicos.
- ☐ Separar desarrollo, demo, pruebas y producción; nunca reutilizar datos ciudadanos entre entornos.

7. Riesgos humanos y de publicación

- No etiquetar reportes ciudadanos como verificados por una autoridad sin validación externa comprobable.
- No exhibir ubicaciones exactas de hogares aislados, niños o solicitantes de ayuda.
- Evitar compartir códigos de seguimiento como enlaces públicos en redes sociales.
- No publicar fotografías sin evaluar reconocimiento de personas, domicilios, vehículos o documentos.
- La base de datos puede contener un indicador verified para organizaciones de ejemplo; no implica legitimidad verificada en campo.
- La visibilidad pública del repositorio GitHub no constituye por sí misma una licencia de software libre. Publicar licencia tras revisar derechos sobre código, marcas y materiales.

8. Criterios de autorización antes de recibir datos reales

Condición	Evidencia mínima esperada
Privacidad	Aviso público, finalidad, retención y responsable identificado.
Seguridad	Revisión de código, roles granulares, protección de GPS/fotos, pruebas de abuso.
Operación	Procedimiento de verificación, derivación y escalamiento coordinado con actores competentes.
Resiliencia	Prueba de restauración, contactos de incidentes y plan de continuidad.
Transparencia	Alcance honesto de la plataforma, sin promesa de atención inmediata.

Referencias técnicas del ZIP

`app/config/bootstrap.php` · `app/config/photos.php` · `index.php` · `assets/js/location.js` · `app/views/public/map.php` · `app/views/public/track.php` · `app/views/public/report.php` · `app/views/panel/needs.php` · `database/schema.sql` · `.htaccess` · `.gitignore`